

Plataforma Digital Municipal

MUNO

Informe Técnico

Hito 1 — Análisis y Arquitectura

Seguridad · Multi-tenancy · Funcionalidad · Infraestructura

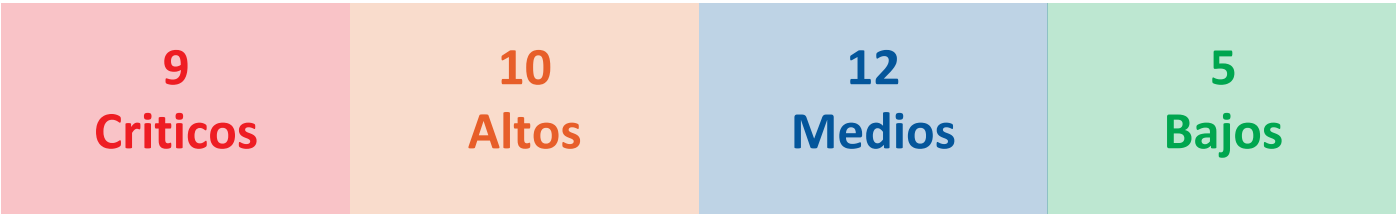
CONTENIDO

01 - Resumen Ejecutivo	Estado y diagnóstico general
02 - Alcance y Metodología	Artefactos analizados y enfoque
03 - Estado General	Diagnóstico por dimensión técnica
04 - Hallazgos Críticos	9 hallazgos
05 - Hallazgos Altos	10 hallazgos
06 - Hallazgos Medios	12 hallazgos
07 - Hallazgos Bajos	5 hallazgos
08 - Matriz de Severidad	36 hallazgos consolidados
09 - Riesgos de Negocio	Impacto sobre la operación
10 - Readiness Institucional	Evaluación para presentación municipal
11 - Aspectos Positivos	Fortalezas detectadas
12 - Plan de Acción — Hito 2	Correcciones en 22 días
13 - Conclusión Ejecutiva	

01 - Resumen Ejecutivo | Estado general de la plataforma

Este informe cierra el Hito 1. El objetivo: revisar sin concesiones el estado técnico de MUNO antes de presentarla en un entorno institucional. Lo que sigue es el resultado de analizar cada archivo de código, cada política de acceso a la base de datos y cada decisión de infraestructura bajo el supuesto de que este sistema operará con datos reales de ciudadanos, enfrentará intentos de acceso no autorizado y deberá crecer hacia múltiples municipios.

El diagnóstico: la plataforma necesita trabajo específico antes de enfrentar una presentación municipal. La arquitectura base es correcta, los problemas son concretos y resolubles, y el Hito 2 tiene un plan definido. Pero en el estado actual, existen vulnerabilidades que podrían ser aprovechadas sin conocimientos técnicos avanzados.



Veredicto ejecutivo

La plataforma **no está en condiciones de presentarse ante la Municipalidad** en este estado. Con las correcciones del Hito 2 aplicadas en sus primeras dos semanas, estará lista para una demo institucional sin vulnerabilidades explotables visibles.

Estado por dimensión	
Autenticación y sesiones	FALLA
Multi-tenancy activo	NO LISTO
Infraestructura HTTP	CRITICO
Funcionalidad core	DEGRADADA
Arquitectura frontend	PARCIAL
CI/CD y monitoreo	AUSENTE
Testing	SIN COBERTURA

02 - Alcance y Metodología | Qué se analizó y cómo

El análisis no asumió buenas intenciones. El código fue revisado con la perspectiva de alguien que busca activamente maneras de saltarse la seguridad, extraer datos sin permiso o escalar privilegios. Esa perspectiva combinada con la del arquitecto que pregunta qué pasa cuando esto escala a 50 municipios es la que produce los hallazgos relevantes.

Artefactos analizados

- Código fuente** | 163 archivos TypeScript/TSX - contextos, páginas, componentes, hooks
- Migraciones SQL** | 16 migraciones PostgreSQL - esquema, RLS, triggers, funciones, índices
- Edge Functions** | Invite-staff · mayor-insights - lógica de negocio y autenticación Deno
- Infraestructura** | Vercel.json · vite.config.ts · package.json · .env · .gitignore
- Políticas RLS** | 47 políticas en 14 tablas - análisis de aislamiento y control de acceso
- Datos mock** | mock.ts - incluyendo contraseñas hardcodeadas detectadas

Partes de auditoria

Principal Software Architect, Security Engineer, Staff Backend Engineer, Performance Engineer, Database Architect, DevOps Engineer, SaaS Multi-Tenant Specialist, OWASP Security Auditor

03 - Estado General de la Plataforma | Diagnóstico por dimensión

MUNO está construida sobre decisiones de arquitectura correctas: el modelo de datos es coherente, el sistema de roles está bien pensado para el contexto municipal argentino y la infraestructura multi-municipio fue planificada desde el inicio. Sin embargo, la velocidad del desarrollo con herramientas de generación de código dejó brechas que requieren corrección antes de la presentación institucional.

Dimensión	Situación actual	Nivel
Autenticación	Preview mode desactiva el acceso; contraseñas triviales para funcionarios	CRÍTICO
Multi-tenancy	Segundo municipio activo; datos sin aislamiento entre municipios	CRÍTICO
Infraestructura HTTP	Sin headers de seguridad en Vercel; CORS abierto en Edge Functions	CRÍTICO
Funcionalidad core	Fotos, analytics e inscripciones no persisten en base de datos	ALTO
Arquitectura frontend	Doble sistema de roles; sin municipality_id en contexto global	ALTO
Performance	N+1 queries; dashboard con datos hardcodeados	MEDIO
DevOps / CI-CD	Sin pipeline, staging ni monitoreo de producción	ALTO
Testing	Vitest configurado; cobertura efectiva 0%	MEDIO

04 - Hallazgos Críticos | 9 hallazgos · Prioridad P0 — Resolver en Semana 1 del Hito 2

Los nueve hallazgos que siguen son vulnerabilidades activas, no teóricas. Tres son explotables sin conocimientos técnicos y dos ya tienen impacto con el segundo municipio activo. Deben resolverse en la primera semana del Hito 2 antes de cualquier demo o compartir del link.

C-01 · CRÍTICO · SEGURIDAD · AUTENTICACIÓN Modo demo activo por defecto para todos los usuarios en producción main.tsx inicializa el modo demostración en localStorage para cada visitante nuevo. ProtectedRoute omite la verificación de JWT cuando ese estado está activo. El mecanismo no tiene ningún guard de entorno: se ejecuta igual en localhost y en producción. IMPACTO TÉCNICO Cualquier ruta del backoffice es accesible sin credenciales. Explotable en la primera visita, sin conocimientos técnicos. IMPACTO DE NEGOCIO En una presentación ante funcionarios, cualquier asistente que abra el link por primera vez verá el panel de gestión municipal sin autenticarse. Probabilidad: Certeza · Prioridad: Urgente — P0 · Esfuerzo: Bajo
C-02 · CRÍTICO · SEGURIDAD · INFRAESTRUCTURA DE RED Contraseñas del WiFi municipal embebidas en el bundle JavaScript público Las credenciales del WiFi municipal ('PLAZA-SFMO-2026', 'SARMIENTO-MUNO') están definidas como constantes en el código fuente. Al compilar, quedan disponibles en el JavaScript descargable por cualquier visitante. IMPACTO TÉCNICO Extraíbles desde DevTools en menos de 30 segundos. El formulario de captación de datos puede ser completamente omitido. IMPACTO DE NEGOCIO La red WiFi municipal queda comprometida. El modelo de captación de leads turísticos pierde toda efectividad. Probabilidad: Certeza · Prioridad: Urgente — P0 · Esfuerzo: Medio
C-03 · CRÍTICO · SEGURIDAD · EDGE FUNCTIONS · DATOS PERSONALES Asistente IA del Intendente accesible sin autenticación con clave de acceso total La Edge Function mayor-insights utiliza SERVICE_ROLE_KEY sin verificar el JWT ni el rol del llamador. Acepta requests de cualquier origen. Cualquier persona que conozca la URL puede consultar el dataset municipal completo. IMPACTO TÉCNICO Un request no autenticado devuelve hasta 300 reclamos con nombres y direcciones de vecinos, 200 comercios con datos fiscales y 200 leads turísticos. IMPACTO DE NEGOCIO Fuga masiva de datos personales. Incumplimiento potencial de la Ley 25.326 de Protección de Datos Personales. Exposición legal directa para el municipio. Probabilidad: Alta · Prioridad: Urgente — P0 · Esfuerzo: Bajo
C-04 · CRÍTICO · SEGURIDAD · BASE DE DATOS · RLS Invitaciones municipales públicamente legibles, emails y roles de funcionarios expuestos La política de seguridad de municipal_invitations usa USING(true), permitiendo a usuarios no autenticados leer todos los registros pendientes: email, rol, área, municipio y token de activación. IMPACTO TÉCNICO Una sola consulta anónima retorna el directorio completo de funcionarios en proceso de onboarding en todos los municipios. IMPACTO DE NEGOCIO Exposición de datos personales de funcionarios. Vector directo para phishing dirigido antes de que activen sus cuentas. Probabilidad: Alta · Prioridad: Urgente — P0 · Esfuerzo: Bajo
C-05 · CRÍTICO · SEGURIDAD · TIEMPO REAL · PRIVACIDAD Notificaciones ciudadanas transmitidas en tiempo real a cualquier suscriptor externo La tabla notifications tiene USING(true) y está registrada en el canal Realtime de Supabase. Cualquier visitante anónimo puede suscribirse al stream en tiempo real de toda la actividad ciudadana de todos los municipios. IMPACTO TÉCNICO Canal Realtime público: notificaciones con user_id vinculado a reclamos, descripciones y estados. Streaming continuo sin autenticación. IMPACTO DE NEGOCIO Vigilancia en tiempo real de actividad ciudadana por terceros. Incompatible con cualquier auditoría de datos. Probabilidad: Alta · Prioridad: Urgente — P0 · Esfuerzo: Bajo
C-06 · CRÍTICO · SEGURIDAD · GESTIÓN DE SECRETOS Credenciales de producción de Supabase expuestas en el repositorio de código El archivo .env con las credenciales del proyecto Supabase de producción está incluido en el repositorio y no figura en .gitignore. Cualquier persona con acceso obtiene credenciales directas a la API. IMPACTO TÉCNICO La anon key permite llamadas directas a la API. El historial de git retiene las credenciales incluso después de eliminar el archivo. IMPACTO DE NEGOCIO Pérdida del control de acceso sobre el entorno de producción. Acceso no autorizado a datos desde herramientas externas. Probabilidad: Alta · Prioridad: Urgente — P0 · Esfuerzo: Bajo

C-07 · CRÍTICO · SEGURIDAD · GESTIÓN DE CONTRASEÑAS

DNI como contraseña inicial de funcionarios, devuelto en texto plano por la API

invite-staff genera cuentas con el DNI como contraseña provisional, la devuelve en plaintext en la respuesta JSON y la muestra en pantalla con opción de copiar. No existe mecanismo que obligue a cambiarla.

IMPACTO TÉCNICO

El DNI es un dato semipúblico. La contraseña figura en la respuesta HTTP y en la UI durante la sesión del administrador.

IMPACTO DE NEGOCIO

Funcionarios con acceso a datos de vecinos y reclamos pueden ser suplantados conociendo solo su número de documento.

Probabilidad: **Alta** · Prioridad: **Urgente — P0** · Esfuerzo: **Medio**

C-08 · CRÍTICO · INFRAESTRUCTURA · SEGURIDAD HTTP

Ausencia total de headers de seguridad HTTP en la configuración de Vercel

vercel.json no define ningún header de seguridad. Están ausentes CSP, X-Frame-Options, X-Content-Type-Options, HSTS, Referrer-Policy y Permissions-Policy.

IMPACTO TÉCNICO

Un XSS exitoso en cualquier campo de texto permite acceder al localStorage donde están los tokens de sesión de Supabase.

IMPACTO DE NEGOCIO

Un único ataque XSS podría comprometer las sesiones de todos los usuarios activos simultáneamente.

Probabilidad: **Media** · Prioridad: **Urgente — P0** · Esfuerzo: **Bajo**

C-09 · CRÍTICO · SEGURIDAD · LÓGICA DE PERMISOS

Trigger de base de datos asigna rol ciudadano a todos los usuarios, incluidos funcionarios

El trigger on_auth_user_created asigna el rol 'resident' a cada cuenta creada en el sistema sin excepción, incluyendo cuentas de funcionarios generadas por invite-staff.

IMPACTO TÉCNICO

Todos los funcionarios invitados acumulan el rol ciudadano, permitiéndoles crear reclamos y contaminar la bandeja administrativa.

IMPACTO DE NEGOCIO

Inconsistencia de permisos silenciosa que se agrava con cada nuevo municipio y cada nuevo funcionario.

Probabilidad: **Certeza** · Prioridad: **Urgente — P0** · Esfuerzo: **Medio**

05 - Hallazgos Altos | 10 hallazgos · Prioridad P1 — Resolver en Semana 2 del Hito 2

Estos diez hallazgos comprenden problemas de multi-tenancy activos, vulnerabilidades de autorización y deficiencias de infraestructura. Deben corregirse en la segunda semana del Hito 2 para que la plataforma sea viable en producción real.

H-01 · ALTO · SEGURIDAD · BASE DE DATOS

Función has_role() SECURITY DEFINER accesible por usuarios anónimos

La función central de permisos fue correctamente revocada para anon en una migración y luego re-otorgada sin justificación documentada en una migración posterior.

IMPACTO TÉCNICO

Usuarios anónimos pueden invocar has_role() con cualquier UUID, enumerando potencialmente qué usuarios tienen roles administrativos.

IMPACTO DE NEGOCIO

Exposición de una función administrativa crítica a usuarios no autenticados. Indica ausencia de proceso de revisión en cambios de seguridad.

Probabilidad: **Media** · Prioridad: **Alta — P1** · Esfuerzo: **Bajo**

H-02 · ALTO · SEGURIDAD · BASE DE DATOS · MULTI-TENANCY

Tabla maestra de municipios permite inserciones sin restricción para cualquier autenticado

Una migración posterior agregó una política que permite a cualquier usuario autenticado insertar registros en municipalities. La justificación 'la UI ya restringe' no es válida como barrera de seguridad.

IMPACTO TÉCNICO

Un vecino registrado puede insertar municipios ficticios directamente via API sin acceso al panel de administración.

IMPACTO DE NEGOCIO

Contaminación de la tabla maestra del sistema. Un municipio falso aparece en el panel ISA Global como cliente real.

Probabilidad: **Media** · Prioridad: **Alta — P1** · Esfuerzo: **Bajo**

H-03 · ALTO · SEGURIDAD · AUTORIZACIÓN

Cualquier usuario autenticado puede calificar reclamos que no le pertenecen

Las políticas RLS de actualización en claims no restringen la operación de rating al propietario del reclamo. Cualquier usuario autenticado puede modificar la calificación de cualquier reclamo.

IMPACTO TÉCNICO

Los UUIDs son visibles en las URLs. La operación de rating es un UPDATE directo a la API sin verificación de autoría.

IMPACTO DE NEGOCIO

Las calificaciones de resolución son los KPIs con que el Intendente evalúa a los jefes de área. Son manipulables sistemáticamente.

Probabilidad: **Media** · Prioridad: **Alta — P1** · Esfuerzo: **Bajo**

H-04 · ALTO · SEGURIDAD · AUTENTICACIÓN

El flujo de registro envía la contraseña del usuario en dos requests separados

Después del signup exitoso, el código ejecuta un `signInWithPassword()` automático con las mismas credenciales, duplicando la transmisión de la contraseña.

IMPACTO TÉCNICO

Doble transmisión de contraseñas. En entornos con logs comprometidos, contraseñas recién creadas quedan expuestas.

IMPACTO DE NEGOCIO

Riesgo de cumplimiento normativo en caso de auditoría de seguridad o compromise de infraestructura de logging.

Probabilidad: Baja · Prioridad: Alta — P1 · Esfuerzo: Bajo

H-05 · ALTO · MULTI-TENANCY · BASE DE DATOS · RLS

Políticas RLS de reclamos sin filtro de municipio - contaminación cross-tenant activa

Ninguna política de claims filtra por `municipality_id`. Con el segundo municipio ya creado en el sistema, esta vulnerabilidad está activa desde hoy.

IMPACTO TÉCNICO

Un jefe de área del municipio A puede leer todos los reclamos del municipio B cuya área coincida con la suya.

IMPACTO DE NEGOCIO

Filtración de datos personales de ciudadanos entre municipios. Incompatible con el modelo SaaS multi-tenant.

Probabilidad: Alta · Prioridad: Alta — P1 · Esfuerzo: Alto

H-06 · ALTO · MULTI-TENANCY · BASE DE DATOS

Anuncios e información de emergencia visibles entre todos los municipios

`announcements` tiene `USING(true)` y `BannersContext` carga todos los banners sin filtrar por municipio. Con múltiples municipios, los vecinos ven alertas de otras localidades.

IMPACTO TÉCNICO

Un alerta de corte de agua de un municipio aparece en la pantalla de inicio de vecinos de otro municipio.

IMPACTO DE NEGOCIO

Información municipal incorrecta para ciudadanos. Pérdida directa de confianza en la plataforma.

Probabilidad: Alta · Prioridad: Alta — P1 · Esfuerzo: Alto

H-07 · ALTO · MULTI-TENANCY · CONFIDENCIALIDAD

Informes analíticos accesibles entre consultores ISA de distintos municipios

La política de `analytics_reports` permite a cualquier `isa_consultant` leer todos los informes de todos los municipios sin restricción por asignación.

IMPACTO TÉCNICO

Un consultor ISA asignado al municipio A puede consultar los informes estratégicos del municipio B directamente desde su panel.

IMPACTO DE NEGOCIO

Violación de confidencialidad entre clientes. Acceso a información sensible de un municipio ajeno.

Probabilidad: Media · Prioridad: Alta — P1 · Esfuerzo: Bajo

H-08 · ALTO · ARQUITECTURA · FRONTEND

Condición de carrera en AuthContext - carga de roles concurrente con estado indeterminado

`AuthContext` dispara `loadRoles()` desde dos flujos concurrentes: `onAuthStateChange` y `getSession()`. Bajo ciertas condiciones de timing, ambos se ejecutan simultáneamente.

IMPACTO TÉCNICO

Dos `setRoles()` concurrentes con resultado indeterminado. `ProtectedRoute` puede recibir array vacío y redirigir incorrectamente.

IMPACTO DE NEGOCIO

Un administrador puede ser redirigido al home en lugar del backoffice durante el login. Genera desconfianza en la estabilidad.

Probabilidad: Media · Prioridad: Alta — P1 · Esfuerzo: Bajo

H-09 · ALTO · DEVOPS · INFRAESTRUCTURA

Sin CI/CD ni entorno de staging - cambios llegan a producción sin validación

No existe pipeline de integración ni entrega continua. El flujo es edición en Lovable → deploy automático a producción. Sin staging ni tests automatizados.

IMPACTO TÉCNICO

Cualquier cambio accidental en Lovable llega a producción sin validación. No hay mecanismo de rollback automatizado.

IMPACTO DE NEGOCIO

Un cambio accidental puede hacer la plataforma inutilizable para todos los municipios simultáneamente.

Probabilidad: Media · Prioridad: Alta — P1 · Esfuerzo: Alto

H-10 · ALTO · SEGURIDAD · EDGE FUNCTIONS

CORS abierto a todos los orígenes en Edge Functions críticas

Ambas Edge Functions definen `Access-Control-Allow-Origin: *`. Para mayor-insights (sin autenticación) esto es directamente explotable. Para `invite-staff` facilita ataques CSRF.

IMPACTO TÉCNICO

Cualquier sitio web puede invocar las Edge Functions usando `fetch()` desde el navegador de un usuario autenticado.

IMPACTO DE NEGOCIO

Las funciones administrativas son invocables desde dominios externos usando sesiones legítimas de usuarios.

Probabilidad: Media · Prioridad: Alta — P1 · Esfuerzo: Bajo

06 - Hallazgos Medios | 12 hallazgos · Prioridad P2

Funcionalidades que aparentan operar correctamente pero presentan fallas de persistencia, arquitectura o performance que afectan la experiencia real en producción.

M-01 · MEDIO · FUNCIONALIDAD · ALMACENAMIENTO Fotos de reclamos almacenadas como URLs efímeras - inaccesibles en producción Al adjuntar fotos, el sistema genera object// URLs locales del dispositivo en lugar de subir archivos a Supabase Storage. Estas URLs dejan de ser válidas al cerrar la pestaña. IMPACTO TÉCNICO El 100% de los reclamos con fotos muestran imágenes rotas para los administradores. No existe bucket de evidencias en Supabase Storage. IMPACTO DE NEGOCIO La evidencia fotográfica es inutilizable. Los administradores gestionan reclamos sin ver las fotos adjuntadas. Probabilidad: Certeza · Prioridad: Alta — P1 · Esfuerzo: Medio
M-02 · MEDIO · FUNCIONALIDAD · ANALÍTICA Analytics de comportamiento almacenado solo en localStorage - datos invisibles Todo el tracking de comportamiento se registra en localStorage. No se persiste en Supabase, es inaccesible desde el backoffice y se pierde al limpiar el caché. IMPACTO TÉCNICO La función track() escribe exclusivamente en localStorage. Supabase tiene las tablas necesarias pero no se usan. IMPACTO DE NEGOCIO El argumento de inteligencia de datos municipal está basado en datos que no se acumulan en producción. Probabilidad: Certeza · Prioridad: Alta — P1 · Esfuerzo: Medio
M-03 · MEDIO · FUNCIONALIDAD · INTEGRIDAD DE DATOS KPIs del dashboard administrativo calculados sobre datos de demostración estáticos AdminDashboard importa datos del archivo mock para calcular los indicadores principales. Estos valores son estáticos y no reflejan la base de datos real en ningún momento. IMPACTO TÉCNICO Las métricas siempre retornan los mismos números, independientemente de la actividad real del sistema. IMPACTO DE NEGOCIO El equipo municipal toma decisiones basadas en números falsos. Los contadores no se actualizan con la actividad real. Probabilidad: Certeza · Prioridad: Alta — P1 · Esfuerzo: Bajo
M-04 · MEDIO · FUNCIONALIDAD · PERSISTENCIA Inscripciones a eventos almacenadas en localStorage - sin respaldo en base de datos El módulo de inscripciones persiste todos sus datos en localStorage. La tabla registrations existe en Supabase con schema completo pero no se usa. IMPACTO TÉCNICO Los jefes de área de Cultura y Deporte no pueden ver ni gestionar inscripciones desde el backoffice. IMPACTO DE NEGOCIO Los municipios no pueden controlar cupos. Los vecinos pierden sus registros al cambiar de dispositivo. Probabilidad: Certeza · Prioridad: Alta — P1 · Esfuerzo: Medio
M-05 · MEDIO · FUNCIONALIDAD · PERSISTENCIA Reservas de comercios solo en estado React - reinician a datos de demo en cada recarga MiComercio gestiona reservas en estado local inicializado desde datos mock. Cada recarga de página reinicia las reservas. No existe tabla de reservas en Supabase. IMPACTO TÉCNICO Funcionalidad que parece operativa pero no persiste ningún dato. Pérdida garantizada en cada reload. IMPACTO DE NEGOCIO Los dueños de hospedaje y restaurantes pierden todas sus reservas al recargar la página. Probabilidad: Certeza · Prioridad: Media — P2 · Esfuerzo: Medio
M-06 · MEDIO · MULTI-TENANCY · BASE DE DATOS Respuestas predefinidas de reclamos compartidas entre todos los municipios claim_canned_responses no tiene municipality_id. Las plantillas creadas por un municipio son visibles y usables en todos los demás. IMPACTO TÉCNICO La política de seguridad no filtra por municipio. Un admin del municipio B puede usar plantillas del municipio A. IMPACTO DE NEGOCIO Respuestas con referencias locales incorrectas se envían a ciudadanos de otro municipio. Probabilidad: Media · Prioridad: Media — P2 · Esfuerzo: Bajo

M-07 · MEDIO · PERFORMANCE · ESCALABILIDAD

Panel ISA Global realiza consultas N+1 secuenciales por municipio

IsaGlobalPanel ejecuta consultas secuenciales por cada municipio en un bucle, sin paralelización ni cacheo. El tiempo de carga crece linealmente.

IMPACTO TÉCNICO

4 consultas × N municipios. Con 20 municipios: 80 round-trips secuenciales sin vistas materializadas.

IMPACTO DE NEGOCIO

El panel de gestión global de ISA se vuelve inutilizable a medida que crece la cartera de municipios.

Probabilidad: **Certeza** · Prioridad: **Media** — P2 · Esfuerzo: **Medio**

M-08 · MEDIO · ARQUITECTURA · FRONTEND

Doble sistema de roles desincronizado - RoleContext de demo vs AuthContext de producción

La aplicación mantiene dos sistemas de roles paralelos e incompatibles: RoleContext (demo) y AuthContext (producción). useSession() los mezcla para determinar el acceso.

IMPACTO TÉCNICO

TouristGate puede confundir el rol del RoleContext con los permisos reales del usuario autenticado.

IMPACTO DE NEGOCIO

Comportamientos de acceso impredecibles. Alta complejidad de mantenimiento que aumenta el riesgo de regresiones.

Probabilidad: **Media** · Prioridad: **Media** — P2 · Esfuerzo: **Alto**

M-09 · MEDIO · ARQUITECTURA · MULTI-TENANCY

MunicipalityContext almacena nombre en texto plano - no el UUID requerido para consultas

MunicipalityContext persiste el nombre del municipio como string legible pero nunca se usa en consultas a Supabase. El municipality_id UUID no se carga en ningún contexto del frontend.

IMPACTO TÉCNICO

Sin municipality_id en el estado global del frontend, es imposible implementar filtros de municipio en las consultas del cliente.

IMPACTO DE NEGOCIO

Bloquea la implementación correcta del modelo multi-municipio, eje central de la propuesta de valor de MUNO.

Probabilidad: **Certeza** · Prioridad: **Media** — P2 · Esfuerzo: **Medio**

M-10 · MEDIO · ARQUITECTURA · RESILIENCIA

Sin ErrorBoundary en el árbol de React - un error puntual tumba toda la aplicación

No existe ningún ErrorBoundary. Un error no capturado en cualquier componente desmontará todo el árbol React y mostrará pantalla en blanco sin mensaje de recuperación.

IMPACTO TÉCNICO

En producción con datos reales, los null references y errores de render son inevitables. Sin ErrorBoundary toda la app queda inutilizable.

IMPACTO DE NEGOCIO

Vecinos y funcionarios ven pantalla en blanco. La inestabilidad afecta la confianza institucional.

Probabilidad: **Media** · Prioridad: **Media** — P2 · Esfuerzo: **Bajo**

M-11 · MEDIO · LÓGICA DE DOMINIO

Panel de colaboradores lista ciudadanos registrados junto con personal municipal

AdminColaboradores filtra por role='resident', que es el mismo rol asignado automáticamente a todos los vecinos registrados.

IMPACTO TÉCNICO

La query no discrimina entre ciudadanos y staff. El mismo rol 'resident' se asigna a ambos por el mismo trigger.

IMPACTO DE NEGOCIO

Con vecinos registrados, el jefe de área no puede identificar a su equipo real entre la lista de ciudadanos.

Probabilidad: **Alta** · Prioridad: **Media** — P2 · Esfuerzo: **Medio**

M-12 · MEDIO · DEVOPS · OBSERVABILIDAD

Sin monitoreo de errores - los incidentes de producción son invisibles para el equipo

No existe logging de errores ni monitoreo. Los errores se capturan con catch y se muestran únicamente como toasts locales al usuario que los experimenta.

IMPACTO TÉCNICO

Fallos de Edge Functions, errores de triggers y excepciones de render son completamente invisibles para el operador.

IMPACTO DE NEGOCIO

El equipo que maneje la app no puede detectar ni responder a incidentes que afecten a los municipios clientes.

Probabilidad: **Certeza** · Prioridad: **Media** — P2 · Esfuerzo: **Medio**

07 - Hallazgos Bajos | 5 hallazgos · Prioridad P3

Deuda técnica y mejoras de calidad que no bloquean la operación actual pero que deben resolverse para la viabilidad a largo plazo.

L-01 · BAJO · SEGURIDAD · GESTIÓN DE SESIONES Sesiones JWT almacenadas en localStorage - susceptibles a robo por XSS El cliente Supabase persiste tokens JWT en localStorage. Un XSS exitoso puede leer y exfiltrar estos tokens. El impacto está condicionado a materializar primero un vector XSS. IMPACTO TÉCNICO Cualquier script JavaScript en el contexto de la página tiene acceso irrestricto a los tokens de sesión. IMPACTO DE NEGOCIO Se mitiga significativamente al implementar CSP del hallazgo C-08. Hallazgo independiente por ser un patrón arquitectónico separable. Probabilidad: Baja · Prioridad: Baja — P3 · Esfuerzo: Medio
L-02 · BAJO · CALIDAD DE CÓDIGO Uso extensivo de 'as any' en TypeScript - type safety desactivada en flujos críticos El código contiene casteos as any en operaciones de inserción y actualización a Supabase. El archivo types.ts generado está correctamente tipado pero no se usa en los flujos principales. IMPACTO TÉCNICO Errores de tipo en campos de datos sensibles pasan silenciosamente a runtime. Cambios en el esquema SQL no generan errores de compilación. IMPACTO DE NEGOCIO Mayor riesgo de inserciones incorrectas en tablas con datos personales. Regresiones difíciles de detectar. Probabilidad: Certeza · Prioridad: Baja — P3 · Esfuerzo: Alto
L-03 · BAJO · CALIDAD DE CÓDIGO · TESTING Suite de testing configurada pero sin cobertura funcional Vitest está correctamente instalado y configurado. El único archivo de test existente contiene un placeholder trivial. No hay cobertura para lógica de roles ni flujos de reclamos. IMPACTO TÉCNICO Las correcciones del Hito 2 se realizarán sin red de seguridad. Cualquier refactor puede introducir regresiones sin detección. IMPACTO DE NEGOCIO En una evaluación técnica formal, la ausencia de tests es un indicador visible de madurez del desarrollo. Probabilidad: Certeza · Prioridad: Baja — P3 · Esfuerzo: Alto
L-04 · BAJO · AUDITORÍA · MULTI-TENANCY Registros de auditoria sin identificación de municipio logActivity() inserta en activity_logs sin incluir municipality_id. La tabla tiene el campo y las migraciones lo definen, pero la función del frontend lo omite. IMPACTO TÉCNICO Los logs de auditoría no pueden filtrarse por municipio desde ningún panel. Trazabilidad por municipio no implementada. IMPACTO DE NEGOCIO Imposibilidad de auditar acciones por municipio. Inconsistencia con los valores de transparencia declarados. Probabilidad: Certeza · Prioridad: Baja — P3 · Esfuerzo: Bajo
L-05 · BAJO · AUDITORÍA · NOTIFICACIONES Notificación de nuevo informe ISA persiste solo en localStorage del navegador Al publicar un informe, la notificación al Intendente se implementa con un flag en localStorage. Invisible en cualquier otro dispositivo. IMPACTO TÉCNICO El badge de nuevo informe no aparece en otro dispositivo ni tras limpiar caché del navegador. IMPACTO DE NEGOCIO La comunicación ISA → Intendente sobre nuevos informes analíticos es poco confiable. Probabilidad: Certeza · Prioridad: Baja — P3 · Esfuerzo: Bajo

08 - Matriz de Severidad | 36 hallazgos consolidados

ID	Hallazgo	Categoría	Severidad	Prioridad
C-01	Modo demo activo por defecto para todos los usuarios en producción	Seguridad	CRÍTICO	Urgente - P0
C-02	Contraseñas del WiFi municipal embebidas en el bundle JavaScript público	Seguridad	CRÍTICO	Urgente - P0
C-03	Asistente IA del Intendente accesible sin autenticación con clave de acceso total	Seguridad	CRÍTICO	Urgente - P0
C-04	Invitaciones municipales públicamente legibles, emails y roles de funcionarios expuestos	Seguridad	CRÍTICO	Urgente - P0
C-05	Notificaciones ciudadanas transmitidas en tiempo real a cualquier suscriptor externo	Seguridad	CRÍTICO	Urgente - P0
C-06	Credenciales de producción de Supabase expuestas en el repositorio de código	Seguridad	CRÍTICO	Urgente - P0
C-07	DNI como contraseña inicial de funcionarios, devuelto en texto plano por la API	Seguridad	CRÍTICO	Urgente - P0
C-08	Ausencia total de headers de seguridad HTTP en la configuración de Vercel	Infraestructura	CRÍTICO	Urgente - P0
C-09	Trigger de base de datos asigna rol ciudadano a todos los usuarios, incluidos funcionarios	Seguridad	CRÍTICO	Urgente - P0
H-01	Función has_role() SECURITY DEFINER accesible por usuarios anónimos	Seguridad	ALTO	Alta - P1
H-02	Tabla maestra de municipios permite inserciones sin restricción para cualquier autenticado	Seguridad	ALTO	Alta - P1
H-03	Cualquier usuario autenticado puede calificar reclamos que no le pertenecen	Seguridad	ALTO	Alta - P1
H-04	El flujo de registro envía la contraseña del usuario en dos requests separados	Seguridad	ALTO	Alta - P1
H-05	Políticas RLS de reclamos sin filtro de municipio — contaminación cross-tenant activa	Multi-tenancy	ALTO	Alta - P1
H-06	Anuncios e información de emergencia visibles entre todos los municipios	Multi-tenancy	ALTO	Alta - P1
H-07	Informes analíticos accesibles entre consultores ISA de distintos municipios	Multi-tenancy	ALTO	Alta - P1
H-08	Condición de carrera en AuthContext - carga de roles concurrente con estado indeterminado	Arquitectura	ALTO	Alta - P1
H-09	Sin CI/CD ni entorno de staging - cambios llegan a producción sin validación	DevOps	ALTO	Alta - P1
H-10	CORS abierto a todos los orígenes en Edge Functions críticas	Seguridad	ALTO	Alta - P1
M-01	Fotos de reclamos almacenadas como URLs efímeras — inaccesibles en producción	Funcionalidad	MEDIO	Alta - P1
M-02	Analytics de comportamiento almacenado solo en localStorage, datos invisibles	Funcionalidad	MEDIO	Alta - P1
M-03	KPIs del dashboard administrativo calculados sobre datos de demostración estáticos	Funcionalidad	MEDIO	Alta - P1
M-04	Inscripciones a eventos almacenadas en localStorage - sin respaldo en base de datos	Funcionalidad	MEDIO	Alta - P1
M-05	Reservas de comercios solo en estado React - reinician a datos de demo en cada recarga	Funcionalidad	MEDIO	Media - P2
M-06	Respuestas predefinidas de reclamos compartidas entre todos los municipios	Multi-tenancy	MEDIO	Media - P2

M-07	Panel ISA Global realiza consultas N+1 secuenciales por municipio	<i>Performance</i>	MEDIO	Media - P2
M-08	Doble sistema de roles desincronizado - RoleContext de demo vs AuthContext de producción	<i>Arquitectura</i>	MEDIO	Media - P2
M-09	MunicipalityContext almacena nombre en texto plano - no el UUID requerido para consultas	<i>Arquitectura</i>	MEDIO	Media - P2
M-10	Sin ErrorBoundary en el árbol de React - un error puntual tumba toda la aplicación	<i>Arquitectura</i>	MEDIO	Media - P2
M-11	Panel de colaboradores lista ciudadanos registrados junto con personal municipal	<i>Lógica de dominio</i>	MEDIO	Media - P2
M-12	Sin monitoreo de errores - los incidentes de producción son invisibles para el equipo	<i>DevOps</i>	MEDIO	Media - P2
L-01	Sesiones JWT almacenadas en localStorage - susceptibles a robo por XSS	<i>Seguridad</i>	Bajo	Baja - P3
L-02	Uso extensivo de 'as any' en TypeScript - type safety desactivada en flujos críticos	<i>Calidad del código</i>	Bajo	Baja - P3
L-03	Suite de testing configurada pero sin cobertura funcional	<i>Calidad del código</i>	Bajo	Baja - P3
L-04	Registros de auditoría sin identificación de municipio	<i>Auditoría</i>	Bajo	Baja - P3
L-05	Notificación de nuevo informe ISA persiste solo en localStorage del navegador	<i>Auditoría</i>	Bajo	Baja - P3

09 - Riesgos de Negocio | Impacto sobre la operación y la relación con el municipio

Más allá de los aspectos técnicos, estos hallazgos tienen consecuencias concretas sobre la capacidad de la plataforma de generar confianza institucional.

Riesgo	Descripción	Refs.	Prob.
Exposición de datos personales	Incumplimiento potencial de la Ley 25.326. Responsabilidad civil y penal del municipio.	C-03, C-05, H-05	Alta
Acceso no autorizado al panel	Ciudadanos y terceros acceden al backoffice sin credenciales.	C-01, C-04	Certeza
Red WiFi municipal comprometida	La infraestructura de red queda accesible sin captación de datos.	C-02	Certeza
Contaminación entre municipios	Con el segundo municipio activo, los datos de vecinos se filtran entre municipios	H-05, H-06, H-07	Alta
Fuga de datos por asistente IA	Terceros consultan el asistente del Intendente sin autenticación.	C-03	Alta
Desconfianza en demo institucional	El backoffice sin login y los KPIs falsos pueden generar rechazo en la presentación.	C-01, M-03	Alta
Módulo de reclamos inoperativo	Las fotos de evidencia son inaccesibles para los administradores en producción.	M-01	Certeza
Plataforma inestable ante errores	Sin ErrorBoundary ni observabilidad, un error puntual tumba toda la app.	M-10, M-12	Media

10 - Readiness para Presentación Institucional

| Evaluación de madurez para demo ante la Municipalidad de San Luis

Dimensión	Estado	Observación
Seguridad básica para demo	NO	9 hallazgos críticos activos. Backoffice accesible sin login (C-01), clave WiFi pública (C-02), sin headers HTTP (C-08).
Protección de datos ciudadanos	NO	Datos personales accesibles por terceros (C-03, C-05). Incompatible con la Ley 25.326.
Aislamiento multi-municipio	NO	Con el segundo municipio activo, los datos se filtran entre municipios (H-05, H-06).
Módulos funcionales en producción	PARCIAL	Fotos (M-01), analytics (M-02), inscripciones (M-04) y reservas (M-05) no persisten en Supabase.
Infraestructura de producción	NO	Sin headers HTTP, sin CI/CD, sin staging y sin monitoreo de errores.
KPIs y métricas confiables	NO	El dashboard principal muestra datos estáticos hardcodeados del archivo mock.
Escalabilidad multi-municipio	PARCIAL	Arquitectura de BD bien diseñada. Políticas RLS y frontend deben actualizarse.
Cumplimiento normativo Ley 25.326	EN RIESGO	Varios hallazgos implican exposición de datos personales sin protección adecuada.

11 - Aspectos Positivos | Fortalezas detectadas en el análisis

El análisis no se limita a identificar problemas. MUNO tiene una base técnica genuinamente sólida con decisiones de diseño correctas que deben preservarse en el Hito 2.

RLS habilitado en todas las tablas	Ninguna tabla tiene políticas desactivadas. El problema está en el contenido, no en la existencia.
Modelo de roles adecuado al contexto	Los 8 roles cubren con precisión la estructura organizativa municipal argentina.
Arquitectura multi-municipio planificada	La tabla municipalities y sus funciones helper demuestran planificación multi-tenant correcta.
Validación robusta en formularios de auth	Zod con reglas completas: mínimo 8 caracteres, mayúscula, número, DNI validado
Jerarquía de roles correcta en invite-staff	Solo admin/mayor pueden crear jefes de área; area_manager solo agrega colaboradores de su área.
Flujo de invitación con token seguro	Tokens de 48 bytes, expiración de 7 días, verificación de email. Diseño robusto.
Sistema de notificaciones en tiempo real	Supabase Realtime correctamente configurado. El problema está en el acceso público, no en el diseño.
Log de auditoría integrado	activity_logs llamado en todas las operaciones administrativas principales.
Auto-desactivación por vencimiento fiscal	businesses_auto_disable() implementa correctamente la lógica de desactivación impositiva.
Separación de privilegios en base de datos	Uso correcto de SECURITY DEFINER/INVOKER para funciones privilegiadas.

12 - Plan de Acción - Hito 2 | 22 días calendario desde la confirmación

Condición de inicio: El trabajo de corrección requiere el freeze de modificaciones en Lovable. Cualquier cambio en Lovable durante el Hito 2 puede invalidar las correcciones aplicadas.

Semana 1 - Días 1–5 - Seg. crítica	
C-08	Agregar headers HTTP en vercel.json (30 min, impacto máximo)
C-01	Eliminar activación de demo en main.tsx
C-06	Eliminar .env del repositorio y rotar credenciales
C-02	Mover contraseñas WiFi a Supabase
C-04	Corregir política municipal_invitations
C-05	Corregir política notifications
C-07	Generar contraseñas aleatorias en invite-staff
C-03	Agregar autenticación JWT en mayor-insights
C-09	Corregir handle_new_user
Semana 2 - Días 6–10 - Multi-tenancy	
H-01	Revocar permisos de has_role() a anon/public
H-02	Restringir INSERT en municipalities a isa_super_admin
H-03	Restringir rating al propietario del reclamo en RLS
H-04	Eliminar auto-signin post-registro
H-05	Crear current_user_municipality_id() y aplicar en RLS
H-06	Filtrar announcements por municipality_id
H-07	Filtrar analytics_reports por municipio ISA
H-08	Refactorizar AuthContext — cargar municipality_id
H-10	Restringir CORS a dominios conocidos
Semana 3 - Días 11–17 - Funcionalidad	
M-01	Subida real a Supabase Storage para fotos
M-02	Persistir analytics en Supabase
M-03	Reemplazar KPIs mock en AdminDashboard
M-04	Conectar InscripcionDialog a tabla registrations
M-05	Crear tabla business_reservations
M-08	Unificar sistema de roles — eliminar RoleContext
M-09	Cargar municipality_id UUID en AuthContext
M-11	Agregar rol 'collaborator' separado de 'resident'
Semana 4 - Días 18–22 - Calidad / DevOps	
M-10	Agregar ErrorBoundary global en App.tsx
M-06	municipality_id en claim_canned_responses
M-07	Vista materializada municipality_counts
H-09	CI/CD básico con GitHub Actions
M-12	Integrar observabilidad de errores
L-01	Migrar sesiones a sessionStorage
L-02	Reemplazar as any con tipos de supabase/types.ts
L-04	municipality_id en logActivity()
L-05	Notificación ISA en tabla notifications

13 - Conclusión Ejecutiva

MUNO tiene las condiciones para convertirse en una plataforma municipal sólida. El modelo de datos es correcto, la granularidad de roles está bien pensada y la planificación multi-municipio fue considerada desde el inicio.

Lo que el análisis revela es que la velocidad del desarrollo dejó decisiones pendientes en seguridad, persistencia de datos y configuración de infraestructura. Ninguna es irreversible. La mayoría de los hallazgos Críticos tienen esfuerzo de corrección Bajo.

9

Críticos

Semana 1

22

Días de corrección

Hito 2 completo

36

Hallazgos totales

Documentados

Recomendación

Proceder al Hito 2 con freeze inmediato de Lovable. Resolver los 9 críticos en la primera semana. Al completar el Hito 2, MUNO estará lista para presentarse ante la Municipalidad de San Luis con datos reales y sin vulnerabilidades explotables visibles.